POLITEKNIK NEGERI BENGKALIS

Jurusan Teknik Informatika · Program Studi D4 Rekayasa Perangkat Lunak

JOBSHEET 4

OWASP Top 10:2025

Nama	Nuraini
NIM	6304240055
Mata kuliah	Keamanan Perangkat Lunak
Pertemuan	4
Topik	OWASP Top 10:2025, pemetaan kategori ke CWE
Praktikum	Eksplorasi kategori pada OWASP Juice Shop secara pasif dan pemetaan ke CWE
Output	Vulnerability Checklist (awal Vulnerability Register)
Dosen pengampu	Muhammad Asep Subandri, M.Kom

A. Tujuan Praktikum

Setelah menyelesaikan jobsheet ini, mahasiswa mampu:

- Menjelaskan tujuan OWASP Top 10 dan perbedaan edisi 2025 dari edisi 2021.
- Menjelaskan 10 kategori OWASP Top 10:2025 beserta CWE representatifnya.
- Mengamati kategori kerentanan pada Juice Shop secara pasif dan mencatat bukti pengamatan.
- Memetakan temuan dan label kategori Juice Shop ke kategori Top 10:2025 dan CWE berdasarkan akar penyebab.
- Melanjutkan register dari Bab 2 menjadi Vulnerability Checklist.

B. Alat dan Bahan

Komponen	Keterangan
Target	OWASP Juice Shop dari pertemuan 1 (http://localhost:3000), berjalan di Docker dengan port terikat ke 127.0.0.1.
Pengamatan	Browser DevTools (Network, Application, Sources) dan History pada OWASP ZAP.
Referensi kategori	owasp.org/Top10/2025 (halaman tiap kategori A01 sampai A10).
Katalog CWE	cwe.mitre.org
Berkas pendukung	Register Bab 2 (Asset & Risk Register) dan tabel pada Lampiran A sampai C jobsheet ini.
Opsional	Python 3 untuk membaca token (Langkah 3c) dan curl untuk memeriksa header (Langkah 3b).

C. Dasar Teori Singkat

1. Apa itu OWASP Top 10

OWASP Top 10 adalah dokumen awareness standar tentang risiko paling kritis pada aplikasi web, disusun dari data pengujian aplikasi dan survei praktisi. Dokumen ini adalah titik awal, **bukan** daftar lengkap kerentanan dan bukan standar kepatuhan. Setiap kategori memuat banyak CWE; sebagai contoh, A01 memetakan 40 CWE.

2. Sepuluh kategori pada edisi 2025

Kategori	Ringkasan	CWE representatif
A01 Broken Access Control	Pengguna dapat bertindak di luar izinnya: akses data orang lain, force browsing, CSRF, SSRF (SSRF kini digabung ke kategori ini).	CWE-200, CWE-639, CWE-862, CWE-918
A02 Security Misconfiguration	Konfigurasi tidak aman: fitur tak perlu aktif, default credential, error verbose, header pengaman hilang. Naik dari #5.	CWE-16, CWE-611, CWE-614
A03 Software Supply Chain Failures	Kegagalan pada build, distribusi, atau pembaruan: dependency rentan, tak terawat, atau disusupi. Baru; memperluas Vulnerable and Outdated Components.	CWE-1104, CWE-1395, CWE-477
A04 Cryptographic Failures	Kriptografi tidak ada, lemah, atau salah pakai: algoritma usang, random lemah, kunci bocor.	CWE-327, CWE-331, CWE-338
A05 Injection	Input tak tepercaya diproses interpreter sebagai perintah: SQL, NoSQL, OS command, dan XSS (XSS tetap termasuk di sini).	CWE-79, CWE-89, CWE-78
A06 Insecure Design	Kontrol keamanan tidak pernah dirancang, termasuk flaw logika bisnis; implementasi sempurna tidak menolong.	CWE-269, CWE-434, CWE-522
A07 Authentication Failures	Sistem keliru mengenali pengguna: credential stuffing, password lemah, session tidak diinvalidasi, recovery lemah.	CWE-287, CWE-307, CWE-798
A08 Software or Data Integrity Failures	Update, artefak, atau data dianggap tepercaya tanpa verifikasi integritas, termasuk insecure deserialization.	CWE-502, CWE-829, CWE-915
A09 Security Logging and Alerting Failures	Kejadian keamanan tidak dicatat, atau tidak memicu alert sehingga serangan terlambat diketahui.	CWE-117, CWE-532, CWE-778
A10 Mishandling of Exceptional Conditions	Aplikasi gagal mencegah, mendeteksi, atau merespons kondisi tak terduga; error terlalu detail atau fail open. Baru.	CWE-209, CWE-476, CWE-636

3. Perubahan dari edisi 2021

- A01 Broken Access Control tetap #1 dan kini memuat SSRF; SSRF tidak lagi berdiri sendiri.
- A02 Security Misconfiguration naik dari #5.
- A03 Software Supply Chain Failures baru, memperluas Vulnerable and Outdated Components ke seluruh rantai pasok perangkat lunak.
- A04 Cryptographic Failures turun dari #2; A05 Injection turun dari #3 dan masih memuat XSS; A06 Insecure Design turun dari #4.

- A07, A08, dan A09 diperjelas namanya (Authentication Failures; Software or Data Integrity Failures; Security Logging and Alerting Failures).
- A10 Mishandling of Exceptional Conditions adalah kategori baru.

4. Kategori, CWE, dan Juice Shop

Kategori Top 10 mengelompokkan banyak **CWE**; satu temuan dipetakan ke CWE yang paling sesuai, lalu ke kategori yang memuat CWE tersebut. Label kategori pada Juice Shop (misalnya Sensitive Data Exposure atau Improper Input Validation) tidak selalu sama dengan nama kategori Top 10:2025, sehingga Anda memetakannya sendiri dari **akar penyebab**, bukan dari gejalanya.

> **Keterbatasan checklist ini**
> Checklist hanya memuat pengamatan pasif: status Teramati atau Hipotesis adalah titik awal untuk diuji pada pertemuan 5 sampai 14. Prioritisasi berdasarkan CVSS dilakukan pada pertemuan 13.

D. Langkah Praktikum

> **Batasan hari ini**
> Praktikum ini hanya **mengamati**. Mengubah parameter, mengirim payload (injection, XSS), mencoba akun atau data pengguna lain, menjalankan active scan ZAP, dan membuka solusi challenge **belum** dilakukan. Bukti yang diperoleh dengan cara tersebut tidak dinilai.
>
> Patuhi Rules of Engagement dari pertemuan 1: target hanya Juice Shop lokal (127.0.0.1).

Langkah 1. Menyiapkan lab dan register

1. Pastikan container Juice Shop berjalan dan port terikat ke 127.0.0.1.
2. Jalankan ZAP, arahkan browser ke proxy ZAP, lalu buka http://localhost:3000.
3. Buka register Bab 2 dan catat ID terakhir (misalnya R-08). ID pada checklist ini dilanjutkan dari sana.
4. Catat versi Juice Shop dan ZAP yang Anda pakai pada catatan lingkungan (Bagian E nomor 1).

```
# Pastikan container Juice Shop berjalan
docker ps

# Bila belum berjalan: ikat port hanya ke 127.0.0.1 agar tidak terbuka ke jaringan
lain
docker run --rm -p 127.0.0.1:3000:3000 bkimminich/juice-shop
```

Langkah 2. Menentukan area pengamatan

1. Baca tabel kategori pada Bagian C.2 dan halaman tiap kategori pada owasp.org/Top10/2025 (bagian Description dan List of Mapped CWEs).
2. Bila Score Board Juice Shop tersedia pada versi yang Anda pakai, baca deskripsi challenge per kategori hanya untuk menentukan area pengamatan. **Jangan mengerjakan challenge-nya.**
3. Bila Score Board tidak tersedia, gunakan daftar kategori challenge pada companion guide Juice Shop (pwning.owasp-juice.shop) sebagai gantinya.

Langkah 3. Mengamati kategori secara pasif

Untuk setiap kategori A01 sampai A10, lakukan pengamatan berikut dan catat hasilnya beserta bukti (screenshot atau potongan request dan response). Tidak menemukan apa-apa adalah hasil yang sah, selama alasannya ditulis.

Kategori	Pengamatan pasif	Kemungkinan temuan	CWE contoh
A01 Broken Access Control	Saat memakai fitur biasa, perhatikan identifier pada URL dan API (nomor keranjang, id pengguna). Catat pola identifier **tanpa mengubah nilainya**. Telusuri file JavaScript klien (tab Sources) untuk rute atau fungsi bernuansa admin; catat saja, jangan dibuka.	Akses objek atau fungsi tanpa otorisasi yang memadai	CWE-639, CWE-862, CWE-200
A02 Security Misconfiguration	Periksa response header (Content-Security-Policy, X-Content-Type-Options, dan sejenisnya), flag cookie, dan informasi teknis pada halaman error.	Header pengaman tidak lengkap; informasi teknis terbuka	CWE-16, CWE-693*
A03 Software Supply Chain Failures	Catat nama dan versi library yang terlihat pada file JavaScript klien (nama file, komentar header). Cari nama dan versi tersebut pada nvd.nist.gov atau osv.dev (hanya pencarian).	Komponen dengan kerentanan publik atau tidak terawat	CWE-1104, CWE-1395
A04 Cryptographic Failures	Catat apakah lab berjalan di HTTP (keterbatasan lab, bukan temuan aplikasi). Baca header dan payload token sesi **milik akun Anda sendiri** (Langkah 3c) dan catat algoritma serta klaim yang tampak.	Algoritma lemah; data sensitif pada token	CWE-327, CWE-331
A05 Injection	Daftarkan titik input (pencarian, login, registrasi, feedback) dan perhatikan di mana input dipantulkan pada halaman atau response. Gunakan teks biasa saja; **jangan mengirim karakter khusus atau payload**.	Hipotesis penanganan input; diuji pada pertemuan 5 dan 9	CWE-89, CWE-79
A06 Insecure Design	Telusuri alur bisnis (kupon, keranjang, pembayaran, review, registrasi) sebagai pengguna biasa. Catat kontrol yang seharusnya ada (batas jumlah, anti-automation, verifikasi) tetapi tidak terlihat. Rujuk Threat Model pada Bab 3.	Flaw desain atau logika bisnis	CWE-501, CWE-522
A07 Authentication Failures	Ulangi pengamatan pertemuan 2: sekitar 10 percobaan login salah pada akun milik sendiri, pendaftaran akun uji dengan password lemah, dan telaah alur Forgot Password (pertanyaan apa yang diminta). **Jangan menjalankan reset pada akun lain.**	Tanpa pembatasan percobaan; password lemah; recovery lemah	CWE-307, CWE-521, CWE-640
A08 Software or Data Integrity Failures	Periksa tag script dan link pada source halaman (Langkah 3d): adakah resource eksternal tanpa atribut integrity? Perhatikan apakah data terstruktur di cookie atau storage tampak dapat diubah klien; catat tanpa mengubahnya.	Resource eksternal tanpa verifikasi integritas	CWE-830, CWE-565
A09 Security Logging and Alerting Failures	Dari sisi klien, amati adakah indikasi pencatatan atau alert. Kategori ini umumnya tidak dapat diamati dari klien; bila demikian, gunakan status Tidak ditemukan dengan alasan "tidak dapat diamati dari sisi klien". Diperdalam pada review kode (pertemuan 11).	Umumnya tidak teramati dari klien	CWE-778, CWE-532
A10 Mishandling of Exceptional Conditions	Akses rute yang tidak ada dan kosongkan kolom wajib pada formulir. Catat apakah pesan error menampilkan stack trace, path, atau versi, dan apakah penanganannya konsisten.	Pesan error terlalu detail; penanganan tidak konsisten	CWE-209, CWE-636

** CWE-693 tidak tercantum pada daftar CWE kategori A02 di OWASP. Boleh dipakai sebagai usulan dengan penjelasan singkat.*

3a. Membaca request di ZAP History. Gunakan fitur biasa (login, pencarian, keranjang, review), lalu telaah entri pada History: metode, URL, header, cookie, dan response.

3b. Memeriksa response header (A02). Selain lewat DevTools atau ZAP, Anda dapat memakai curl:

```
# Mengambil header response halaman utama Juice Shop (tanpa body; -s = senyap, -I =
HEAD)
curl -sI http://127.0.0.1:3000

# Periksa apakah header berikut ada, lalu catat hasilnya:
#   Content-Security-Policy       -> pembatas sumber script yang boleh dimuat
#   X-Content-Type-Options        -> mencegah browser menebak tipe konten
#   Strict-Transport-Security     -> hanya relevan bila memakai HTTPS (lab memakai
HTTP)
```

3c. Membaca token sesi milik akun Anda sendiri (A04). Setelah login dengan akun uji Anda, salin token dari tab Application pada DevTools, lalu jalankan skrip berikut. Skrip hanya membaca (decode); tidak memverifikasi, mengubah, atau menggunakan ulang token.

```
# decode_jwt.py - membaca header dan payload JWT milik akun Anda sendiri
# Penggunaan: python decode_jwt.py <token>
import base64, json, sys

def b64url_decode(segment):
    # JWT memakai base64url tanpa karakter padding '='; tambahkan sebelum decode
    segment += "=" * (-len(segment) % 4)
    return base64.urlsafe_b64decode(segment)

token = sys.argv[1]
header, payload, _signature = token.split(".")   # bagian signature diabaikan

# Perhatikan field "alg" pada header dan klaim apa saja yang ada pada payload
print("HEADER :", json.dumps(json.loads(b64url_decode(header)), indent=2))
print("PAYLOAD:", json.dumps(json.loads(b64url_decode(payload)), indent=2))
```

Catat algoritma (`alg`), klaim yang tampak, dan apakah ada data sensitif pada payload. Jangan membagikan token Anda.

3d. Memeriksa resource eksternal (A08). Cari tag script dan link yang memuat resource dari domain lain, lalu periksa apakah ada atribut `integrity`:

```
# Menampilkan tag <script> dan <link> yang memuat resource dari alamat http(s)
eksternal
curl -s http://127.0.0.1:3000 | grep -Eo
'<(script|link)[^>]+(src|href)="https?://[^"]+"[^>]*>'

# Tidak ada keluaran = tidak ada tag eksternal pada HTML awal (aplikasi ini memuat
banyak bagian lewat JavaScript).
# Alternatif tanpa curl: DevTools > Elements, cari tag script/link dan lihat
atributnya.
# Atribut integrity="sha384-..." menandakan Subresource Integrity (verifikasi hash
resource).
```

Langkah 4. Memetakan ke CWE dan menetapkan status

1. Untuk setiap pengamatan, pilih CWE yang paling sesuai. Mulailah dari bagian List of Mapped CWEs pada halaman kategori OWASP, lalu rujuk cwe.mitre.org untuk definisinya.
2. Bila CWE yang Anda pilih tidak tercantum pada daftar kategori, tandai sebagai **usulan** dan jelaskan alasannya dalam satu kalimat.

3. Tetapkan status: **Teramati** (ada bukti langsung), **Hipotesis** (ada indikasi, belum dapat dibuktikan), atau **Tidak ditemukan** (sudah diamati, tidak ada indikasi; tulis alasan).
4. Tentukan kategori dari **akar penyebab**. Contoh: pesan error yang menampilkan stack trace dipetakan ke A10 (CWE-209), bukan ke A05 meskipun dipicu oleh input.

Langkah 5. Melanjutkan register menjadi Vulnerability Checklist

1. Isi tabel Lampiran A. Lanjutkan ID dari baris terakhir Bab 2 (R-09, R-10, dan seterusnya).
2. Hubungkan setiap baris dengan ID aset dari Bab 2 (A-xx) pada kolom Aset.
3. Pastikan seluruh kategori A01 sampai A10 tercakup dengan minimal 10 baris, dan minimal 6 kategori memiliki bukti. Gunakan Lampiran C untuk memeriksa cakupan.

Contoh baris (ilustrasi format):

ID	Aset	Kategori	Label Juice Shop	CWE	Status	Bukti
R-09	A-04	A10	Security Misconfiguration	CWE-209	Teramati	Screenshot pesan error pada rute yang tidak ada (file bukti-r09.png)

Langkah 6. Memetakan label Juice Shop ke Top 10:2025

1. Isi tabel Lampiran B dengan minimal **8 label** kategori Juice Shop (misalnya Injection, Broken Authentication, Sensitive Data Exposure, Improper Input Validation).
2. Untuk tiap label, tulis kategori 2025, CWE pendukung, dan alasan berdasarkan akar penyebab.
3. Bila satu label dapat masuk lebih dari satu kategori, tulis semuanya dan jelaskan kondisi yang membedakan.

Langkah 7. Refleksi

Tulis 3 sampai 4 kalimat: mengapa A03 Software Supply Chain Failures dan A10 Mishandling of Exceptional Conditions menjadi kategori baru, dan apa artinya bagi aplikasi Laravel yang Anda bangun (misalnya pengelolaan dependency Composer dan penanganan exception).

E. Output dan Pengumpulan

Seluruh output menjadi **Bab 4** pada laporan berjalan. Kumpulkan dalam satu file PDF dengan nama NIM_Nama_Bab4.pdf.

No	Bagian laporan	Isi
1	Catatan lingkungan	Versi Juice Shop dan ZAP yang dipakai, tanggal praktikum, dan apakah Score Board tersedia.
2	Vulnerability Checklist	Minimal 10 baris, semua kategori A01 sampai A10 tercakup, minimal 6 kategori memiliki bukti. ID melanjutkan Bab 2.
3	Pemetaan label ke Top 10:2025	Minimal 8 label Juice Shop dengan kategori, CWE pendukung, dan alasan.
4	Refleksi	3 sampai 4 kalimat tentang A03 dan A10.

F. Rubrik Penilaian

Komponen	Kriteria utama	Bobot
Pemetaan kategori	Seluruh A01 sampai A10 tercakup; kategori sesuai akar penyebab; minimal 8 label Juice Shop terpetakan ke Top 10:2025	25
Bukti pengamatan	Minimal 6 kategori berbukti; bukti jelas (screenshot atau request/response) dan diperoleh secara pasif	25
Pemetaan CWE	CWE tepat dan tercantum pada kategori, atau ditandai usulan dengan alasan	20
Kelanjutan register	ID melanjutkan Bab 2, kolom Aset terhubung, status konsisten dengan bukti	15
Refleksi dan kerapian	Refleksi menunjukkan pemahaman A03 dan A10; laporan rapi dan sesuai format	15
Total		**100**

Bobot rubrik ini disusun untuk pertemuan 4 dan dapat disesuaikan bila ada standar rubrik jurusan.

G. Pemecahan Masalah dan Referensi

Pemecahan masalah

Masalah	Kemungkinan penyebab	Tindakan
Juice Shop tidak terbuka	Container belum berjalan atau port berbeda	Jalankan `docker ps`; pastikan port 3000 terikat ke 127.0.0.1.
Request tidak muncul di ZAP History	Browser belum diarahkan ke proxy ZAP	Periksa pengaturan proxy browser dan port proxy ZAP, lalu muat ulang halaman.
Score Board tidak ditemukan	Bergantung versi dan konfigurasi Juice Shop	Pakai daftar kategori pada companion guide; jangan mengerjakan challenge-nya.
Tidak menemukan bukti untuk suatu kategori	Wajar; banyak kategori memerlukan pengujian aktif	Tulis Tidak ditemukan atau Hipotesis beserta alasannya.
CWE tidak ada pada daftar kategori	CWE tidak dipetakan OWASP ke kategori tersebut	Cari di cwe.mitre.org, tandai sebagai usulan, dan jelaskan alasannya.

Referensi

- OWASP, OWASP Top 10:2025 (owasp.org/Top10/2025).
- MITRE, Common Weakness Enumeration (cwe.mitre.org).
- OWASP Juice Shop dan companion guide Pwning OWASP Juice Shop (pwning.owasp-juice.shop).
- OWASP ZAP (zaproxy.org).
- OWASP Web Security Testing Guide (owasp.org/www-project-web-security-testing-guide).

Catatan Lingkungan

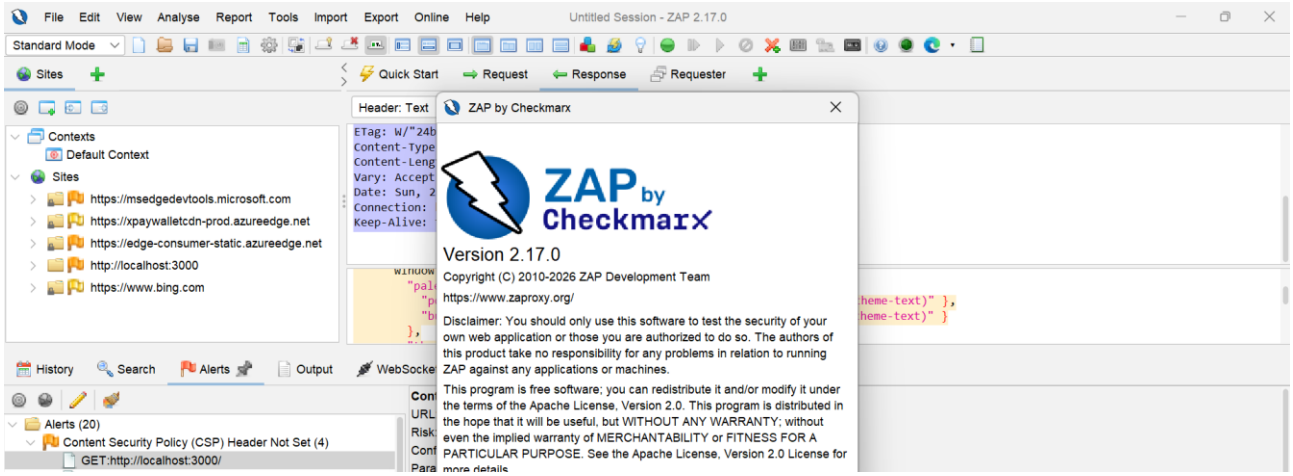
Tanggal Praktikum:22-10-2026

Versi juice shop

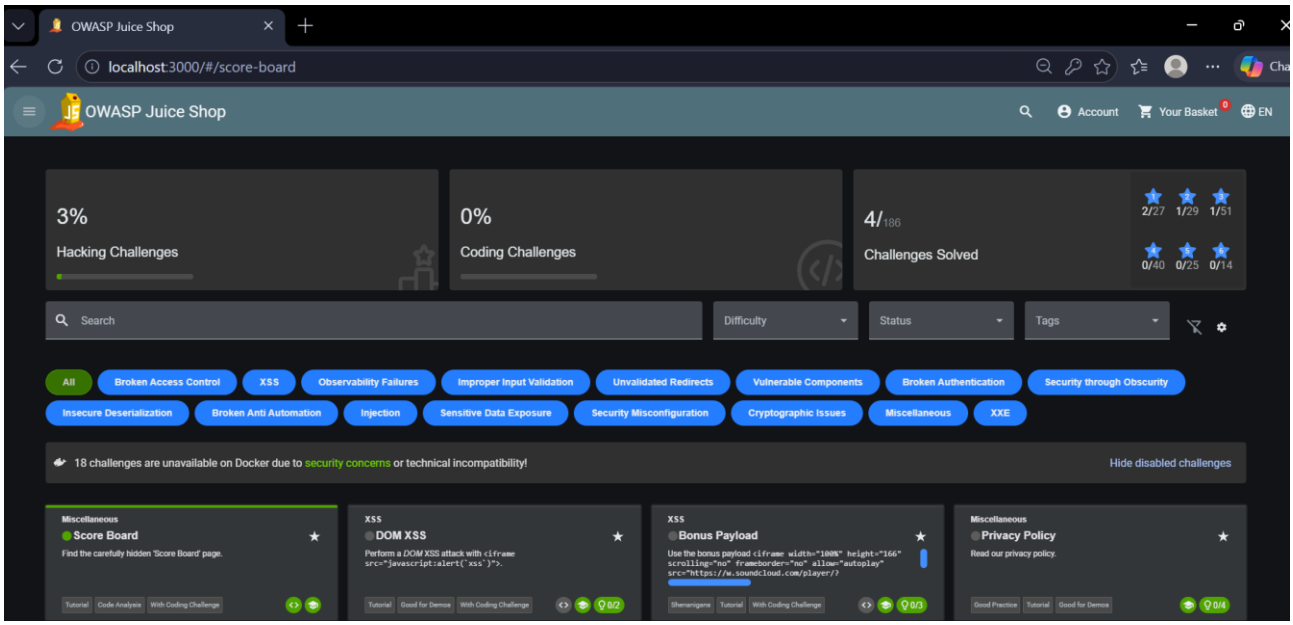
```
C:\Users\ACER1>docker image inspect bkimminich/juice-shop --format "{{json .Config.Labels}}"
{"maintainer":"Bjoern Kimminich <bjoern.kimminich@owasp.org>","org.opencontainers.image.authors":"Bjoern Kimminich <bjoern.kimminich@owasp.org>","org.opencontainers.image.created":""2026-08-11T05:21:13Z"","org.opencontainers.image.description":"Probably the most modern and sophisticated insecure web application","org.opencontainers.image.documentation":"https://help.owasp-juice.shop","org.opencontainers.image.licenses":"MIT","org.opencontainers.image.revision":"5658473","org.opencontainers.image.source":"https://github.com/juice-shop/juice-shop","org.opencontainers.image.title":"OWASP Juice Shop","org.opencontainers.image.url":"https://owasp-juice.shop","org.opencontainers.image.vendor":"Open Worldwide Application Security Project","org.opencontainers.image.version":"20.2.0"}

C:\Users\ACER1>
```

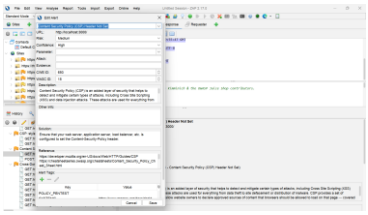
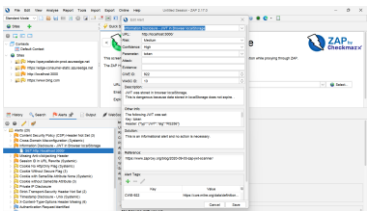
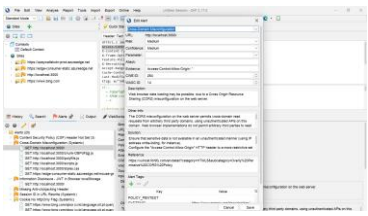
Versi ZAP



Score Board



Lampiran A. Template Vulnerability Checklist

ID	Aset	Kategori	Label Juice Shop	CWE	Status	Bukti
R-8	Halaman utama Juice Shop (localhost:3000)	A02 — Security Misconfiguration	Content Security Policy (CSP) Header Not Set	CWE-693	Teramati	ZAP Passive Scan mendeteksi Risk Medium dan Confidence High. Respons GET / berstatus 200 OK dan tidak memiliki header Content-Security-Policy. 
R-9	Halaman utama Juice Shop (localhost:3000)	A07 — Authentication Failures	Information Disclosure – JWT in Browser localStorage	CWE-922	Teramati	
R-10	Halaman utama Juice Shop (localhost:3000)	A02 – Security Misconfiguration	Cross-Domain Misconfiguration	CWE-264	Teramati	
R-11	Aset aplikasi web	A02	X-Content-Type-Options Header Missing	CWE-693	Teramati	Response endpoint Socket.IO tidak memuat header X-Content-Type-Options. Dampak belum terbukti.
R-12	Aset aplikasi web	A02	Missing Anti-clickjacking Header	CWE-1021*	Hipotesis	Alert terlihat di ZAP, tetapi response yang diperiksa belum cukup untuk memastikan header tidak tersedia pada endpoint terkait.
R-13	Aset aplikasi web	A04	Information Disclosure – JWT in Browser localStorage	CWE-922	Teramati	Alert ZAP menunjukkan JWT disimpan di localStorage. Penyimpanan ini sendiri belum membuktikan kelemahan kriptografi.

ID	Aset	Kategori	Label Juice Shop	CWE	Status	Bukti
R-14	Aset aplikasi web	A01	Broken Access Control	CWE-862	Hipotesis	Endpoint /rest/basket/6 memberikan 200 OK, tetapi belum ada bukti bahwa data dapat diakses oleh pengguna yang tidak berwenang.
R-15	Aset aplikasi web	A03	Software Supply Chain Failures	CWE-1104	Tidak ditemukan	File main.js ditemukan, tetapi pencarian node_modules/ tidak menemukan teks tersebut dan versi library rentan belum teridentifikasi.
R-16	Aset aplikasi web	A05	Injection	CWE-79	Hipotesis	Form login memiliki input email dan password. Belum ada bukti bahwa input menyebabkan injeksi atau perubahan perilaku aplikasi.
R-17	Aset aplikasi web	A07	Authentication Failures	CWE-287	Hipotesis	Login dengan kredensial yang tidak valid menghasilkan pesan Invalid email or password. Belum ada bukti kegagalan autentikasi.
R-18	Aset aplikasi web	A06	Insecure Design	CWE-840*	Hipotesis	Belum ada bukti langsung mengenai kelemahan desain keamanan dari pengamatan pasif.
R-19	Aset aplikasi web	A08	Software or Data Integrity Failures	CWE-345*	Hipotesis	Belum ada bukti langsung mengenai kegagalan verifikasi integritas perangkat lunak atau data.
R-20	Aset aplikasi web	A09	Security Logging and Alerting Failures	CWE-778	Tidak ditemukan	Pengamatan yang dilakukan belum memberikan bukti yang cukup untuk menilai pencatatan log dan alert keamanan.
R-21	Aset aplikasi web	A10	Mishandling of Exceptional Conditions	CWE-209	Hipotesis	Pernah terlihat pesan 401 UnauthorizedError: No Authorization header was found, tetapi belum dipastikan apakah informasi internal sensitif terekspos pada response yang relevan.

Status: Teramati, Hipotesis, atau Tidak ditemukan. Tambahkan baris sesuai kebutuhan.

Lampiran B. Template Pemetaan Label Juice Shop ke Top 10:2025

No	Label Juice Shop	Kategori 2025	CWE pendukung	Alasan (akar penyebab)
1	Content Security Policy (CSP) Header Not Set	A02 – Security Misconfiguration	CWE-693	Header CSP tidak ditemukan pada response halaman utama sehingga browser tidak memperoleh kebijakan CSP dari server untuk membatasi sumber konten yang diizinkan.
2	Cross-Domain Misconfiguration	A02 – Security Misconfiguration	CWE-942	Response menggunakan Access-Control-Allow-Origin: *, yang memungkinkan akses lintas origin. Dampaknya bergantung pada endpoint dan jenis data yang diakses.
3	X-Content-Type-Options Header Missing	A02 – Security Misconfiguration	CWE-693	Header X-Content-Type-Options tidak ditemukan pada response endpoint Socket.IO yang diperiksa. Hal ini menunjukkan konfigurasi header keamanan yang belum lengkap pada endpoint tersebut.
4	Missing Anti-clickjacking Header	A02 – Security Misconfiguration	CWE-1021	ZAP menampilkan alert terkait perlindungan clickjacking. Perlu memeriksa response endpoint terkait untuk memastikan header perlindungannya memang tidak tersedia.
5	Information Disclosure – JWT in Browser localStorage	A04 – Cryptographic Failures (pemetaan sementara)	CWE-922	JWT terdeteksi tersimpan di localStorage. Penyimpanan ini dapat meningkatkan risiko pencurian token jika terjadi XSS, tetapi tidak membuktikan bahwa algoritma kriptografinya lemah.
6	Broken Access Control	A01 – Broken Access Control (hipotesis)	CWE-862	Endpoint keranjang memberikan response 200 OK, tetapi belum ada bukti bahwa pengguna dapat mengakses keranjang milik pengguna lain tanpa izin.
7	Injection	A05 – Injection (hipotesis)	CWE-79	Form login memiliki input yang menerima data pengguna. Namun, belum ditemukan bukti bahwa input tersebut dieksekusi atau dipantulkan secara tidak aman.
8	Mishandling of Exceptional Conditions	A10 – Mishandling of Exceptional Conditions (hipotesis)	CWE-209	Pesan 401 UnauthorizedError: No Authorization header was found terlihat, tetapi perlu memastikan apakah response tersebut mengekspos informasi internal yang seharusnya tidak ditampilkan.

Lampiran C. Pemeriksaan Cakupan

Kategori	Jumlah baris pada checklist	Berbukti? (ya/tidak)
A01 Broken Access Control	1	Tidak
A02 Security Misconfiguration	4	Ya
A03 Software Supply Chain Failures	1	Tidak
A04 Cryptographic Failures	1	Ya
A05 Injection	1	Tidak
A06 Insecure Design	1	Tidak
A07 Authentication Failures	2	Tidak
A08 Software or Data Integrity Failures	1	Tidak
A09 Security Logging and Alerting Failures	1	Tidak
A10 Mishandling of Exceptional Conditions	1	Tidak

Syarat: setiap kategori memiliki minimal satu baris, total minimal 10 baris, dan minimal 6 kategori berbukti.